

Área de Conocimiento de Tecnología de la Información y Comunicación

Auditoría de Sistemas

**Resumen de la auditoría a la infraestructura física de la red de datos de la sede principal
y verificación del cumplimiento de las normas de gobierno en línea en la página de la
ESE Centro Hospital Divino Niño**

Elaborado por:

Docente:

Br. Gerson Antonio
Valdivia

Br. Stephanie Lucía
Mora Chávez

Msc. Leonel Antonio Martínez Zuniga

Br. Haxell Antonio
Trejos Rodríguez

Br. Arleth del Rosario
Velásquez Gómez

Br. Alison Michelle
Navarro Goussen

06 de junio, 2026
Managua, Nicaragua

INFORME DE AUDITORÍA DE SISTEMAS

ENTIDAD AUDITADA: E.S.E. Centro Hospital Divino Niño

MUNICIPIO: San Andrés de Tumaco, Nariño

FECHA DEL INFORME: Mayo de 2013

AUDITOR RESPONSABLE: Luis Alberto Reynel Araujo

1. INTRODUCCIÓN

Actualmente los sistemas de información y las tecnologías de información han cambiado la forma en que operan las organizaciones. A través de su uso se logran importantes mejoras, pues automatizan los procesos operativos, suministran una plataforma de información necesaria para la toma de decisiones y, lo más importante, su implantación logra ventajas operativas que se traducen en beneficios para las instituciones o empresas.

La seguridad de la información debe ser un proceso integrado. Esto quiere decir que con el uso de controles técnicos, administrativos y físicos, se debe lograr la confianza en los sistemas y garantizar que cumplan con los parámetros de disponibilidad, integridad, confidencialidad, confiabilidad y desempeño.

Desde el punto de vista de los sistemas de información se presenta un proyecto para evaluar por medio de un trabajo de auditoría de sistemas los controles relacionados con la seguridad física de la información que maneja diariamente la E.S.E. Centro Hospital Divino Niño, para desempeñar a cabalidad sus funciones y brindar un adecuado servicio a la comunidad.

2. OBJETIVOS

2.1. Objetivo General

Aplicar una auditoría de sistemas para evaluar la infraestructura física de la red de datos de la sede principal de la E.S.E. Centro Hospital Divino Niño, para evidenciar vulnerabilidades de seguridad física a las que se encuentra expuesta la información, y el cumplimiento del Decreto 1151 de Gobierno en Línea.

2.2. Objetivos Específicos

- Realizar una auditoría para evaluar la infraestructura física de la red de datos y establecer el grado de confiabilidad de esta.
- Establecer las recomendaciones necesarias para mejorar la infraestructura de la red.
- Aplicar la auditoría al portal de la E.S.E. Centro Hospital Divino Niño para verificar el cumplimiento del Decreto 1151 de Gobierno en Línea.
- Realizar las recomendaciones necesarias para ayudar a mejorar el portal web.

3. ALCANCE DE LA AUDITORÍA

La aplicación de técnicas de auditoría de sistemas se realizó a la infraestructura de la red de datos de la sede principal y a la página web de la E.S.E. Centro Hospital Divino Niño en el municipio de San Andrés de Tumaco. Con esto se identificó, comprobó y evaluó las vulnerabilidades de seguridad física a las que está expuesta la entidad en su red de datos de la sede principal. Además, se auditó el sitio web de la entidad y se verificó si cumplía con los lineamientos del Decreto 1151 de 2008 de la estrategia de Gobierno en Línea.

Limitaciones identificadas durante la auditoría:

La auditoría se realizó con completa normalidad; sin embargo, cabe resaltar que en ningún momento se tuvo acceso a servidores en funcionamiento, routers o switches, ya que esto no hacía parte de los lineamientos de la auditoría. Tampoco se tuvo acceso a información de hardware de la red de datos e información como planos de red, debido a que no existe ningún plano, ni inventario de hardware de equipos de comunicaciones (la mayoría son del proveedor de internet), lo que impidió diagnosticar el proceso de normas y certificación de puntos de la red montada en la sede principal.

Con respecto a las pruebas de seguridad planeadas para el portal web (spiders, robots, crawlers, reconocimiento mediante motores de búsqueda, identificación de puntos de entrada, pruebas de fuerza bruta, inyección SQL, entre otras), estas no se pudieron realizar porque el servicio de hosting que albergaba la página se venció y no fue levantado durante el periodo de auditoría.

4. METODOLOGÍA DE LA AUDITORÍA

Para realizar esta auditoría de sistemas se utilizó una metodología de tipo de **investigación cuantitativa**, ya que permite examinar los datos de manera científica, específicamente en forma numérica, con ayuda de herramientas del campo de la estadística. También se empleó una metodología de **tipo empírico**, porque se realiza recolección y análisis de datos, tomando como fuente primaria de información la observación directa por parte del auditor. Esta metodología se clasifica dentro del tipo de **investigación aplicada**, ya que todas las recomendaciones finales deberán ser aplicadas para tener un funcionamiento de calidad.

El marco de referencia utilizado fue **COBIT (Objetivos de Control para la Información y Tecnologías Relacionadas)**. Para el caso de la evaluación del portal web, se aplicaron los lineamientos establecidos en el **Decreto 1151 de 2008** (estrategia de Gobierno en Línea) y una medición de usabilidad.

La auditoría se dividió en las siguientes **cuatro etapas**:

1. **Etapla I. Familiarización con el Entorno:** Estudio previo para conocer en detalle la entidad auditada, la infraestructura física de la red y el portal web. Se realizaron visitas a la entidad con contacto directo con el personal de la oficina de sistemas y observación directa de equipos de cómputo, redes de datos y servidores.

2. **Etapa II. Planeación de la Auditoría:** Identificación del alcance y los objetivos, realización del estudio inicial para recolectar datos, determinación de los recursos necesarios y elaboración del plan de trabajo.
3. **Etapa III. Realización de las Actividades de la Auditoría:** Ejecución de los planteamientos de la etapa anterior mediante la aplicación de las metodologías y técnicas seleccionadas. Incluyó la elaboración del plan de auditoría basado en los dominios de COBIT, cuadros de definición de fuentes de conocimiento, cuestionarios cuantitativos, identificación de hallazgos y el análisis del cumplimiento del Decreto 1151.
4. **Etapa IV. Presentación del Informe Final:** Elaboración del informe dirigido a la E.S.E. Centro Hospital Divino Niño, con la descripción de hallazgos, recomendaciones y el análisis del portal web.

5. ÁREAS AUDITADAS

Para el proceso de auditoría al funcionamiento del aspecto físico de la red de datos, se utilizó la metodología COBIT, evaluando objetivos de control específicos dentro de los siguientes **cuatro dominios**:

- **Dominio – Planificación y Organización (PO):** Procesos PO1, PO3, PO4, PO5 y PO9.
- **Dominio – Adquisición e Implementación (AI):** Procesos AI2 y AI3.
- **Dominio – Entregar y Dar Soporte (DS):** Proceso DS12.
- **Dominio – Monitorear y Evaluar (ME):** Proceso ME2.

Adicionalmente, se auditó el portal web institucional en cuanto al cumplimiento del Decreto 1151 de 2008 y su nivel de usabilidad.

6. DETERMINACIÓN DE PROCESOS DE CONTROL

Los procesos y objetivos de control evaluados para el Centro Hospital Divino Niño, según el marco COBIT, fueron los siguientes:

Dominio	Proceso COBIT	Objetivos de Control Específicos Evaluados
Planear y Organizar (PO)	PO1 - Definir un Plan Estratégico de TI	PO1.3 Evaluación del Desempeño y la Capacidad Actual; PO1.4 Plan Estratégico de TI

Dominio	Proceso COBIT	Objetivos de Control Específicos Evaluados
	PO3 - Determinar la Dirección Tecnológica	PO3.1 Planeación de la Dirección Tecnológica
	PO4 - Definición de la Organización y de las Relaciones de TI	PO4.6 Establecimiento de Roles y Responsabilidades; PO4.13 Personal Clave de TI
	PO5 - Administrar la Inversión en TI	PO5.1 Marco de Trabajo para la Administración Financiera; PO5.2 Prioridades Dentro del Presupuesto de TI
	PO9 - Evaluación y Análisis de Riesgos	PO9.1 Marco de Trabajo de Administración de Riesgos; PO9.3 Identificación de Eventos; PO9.4 Evaluación de Riesgos de TI; PO9.5 Respuesta a los Riesgos; PO9.6 Mantenimiento y Monitoreo de un Plan de Acción de Riesgos
Adquirir e Implementar (AI)	AI2 - Adquirir y Mantener Software Aplicativo	AI2.5 Configuración e Implantación de Software Aplicativo Adquirido; AI2.10 Mantenimiento de Software Aplicativo
	AI3 - Adquirir y Mantener la Infraestructura Tecnológica	AI3.1 Plan de Adquisición de Infraestructura Tecnológica; AI3.3 Mantenimiento de la Infraestructura
Entregar y Dar Soporte (DS)	DS12 - Administración de Instalaciones	DS12.1 Selección y Diseño del Centro de Datos; DS12.2 Medidas de Seguridad Física; DS12.3 Acceso Físico; DS12.5 Administración de Instalaciones Físicas
Monitorear y Evaluar (ME)	ME2 - Evaluar lo Adecuado del Control Interno	ME2.1 Monitoreo del Marco de Trabajo de Control Interno; ME2.7 Acciones Correctivas

7. RESUMEN DE LA INFRAESTRUCTURA

Con base en la observación directa y la información recolectada durante la fase de familiarización y los hallazgos, se pudo constatar el siguiente estado de la infraestructura física de la red de datos en la sede principal:

- **Centro de Cómputo:** No se cuenta con una implementación adecuada del centro de cómputo ni con características ajustadas a la normatividad correspondiente.
- **Cableado Estructurado:** No se tiene una implementación adecuada de cableado estructurado ni existen planos que documenten su extensión por la entidad.
- **Equipos de Comunicación:** Elementos como switches, routers y servidores no cuentan con un proceso de mantenimiento formal ni hojas de vida que recolecten la información necesaria para un adecuado seguimiento. Se identificó que la mayoría de estos equipos son propiedad del proveedor de servicios de internet.
- **Seguridad Física:** El lugar donde se ubican los servidores y otros equipos de comunicación no cuenta con dispositivos de seguridad como detectores de humo o supresores de fuego. No existen mecanismos de control de acceso físico, como requisas o escolta de visitantes, ni sistemas de monitoreo por cámaras. No se cuenta con pólizas de seguro para los elementos de la red.
- **Software de Monitoreo:** La entidad no posee ningún tipo de software para monitorear la conexión física de la red de datos.
- **Documentación:** Existe una carencia generalizada de documentación, incluyendo manuales de funciones específicos para el personal de sistemas, planes de contingencia, políticas de mantenimiento y procedimientos para la adquisición de hardware.

8. PRUEBAS TÉCNICAS

8.1. Diseño de Instrumentos de Auditoría para la Red de Datos

Para la evaluación de la red física de datos se diseñaron y aplicaron los siguientes instrumentos, enmarcados en la metodología COBIT:

- **Cuadro de Definición de Fuentes de Conocimiento, Pruebas de Análisis y de Auditoría:** Se elaboró un instrumento para identificar la información necesaria para evaluar cada proceso COBIT, especificando las fuentes de conocimiento y las pruebas de análisis y ejecución. Se utilizó para todos los procesos auditados.
- **Cuestionario Cuantitativo:** Se aplicó un cuestionario para asignar una calificación numérica a los requerimientos de cada proceso, determinando su nivel de vulnerabilidad

mediante un porcentaje de riesgo. La escala de valoración fue de 1 a 5 y el nivel de riesgo total se categorizó como Bajo (1%-30%), Medio (31%-70%) y Alto (71%-100%).

- **Matriz de Probabilidad de Ocurrencia e Impacto:** Se utilizó una matriz para catalogar el riesgo de cada hallazgo, combinando la probabilidad de ocurrencia (alta, media o baja) con el impacto según la relevancia del proceso (leve, moderado o catastrófico). Las zonas de riesgo resultantes se clasificaron en tolerable, moderado, importante e inaceptable.

8.2. Pruebas para el Portal Web

- **Verificación de Cumplimiento Decreto 1151:** Se aplicó una lista de chequeo con los 49 criterios del Decreto 1151 de 2008 sobre Gobierno en Línea, verificando su cumplimiento en el portal web institucional.
- **Medición de Usabilidad:** Se realizó una evaluación cuantitativa del nivel de usabilidad del portal web, analizando factores como comprensibilidad global, mecanismos de ayuda, aspectos estéticos, accesibilidad, funcionalidad, contenidos, confiabilidad y eficiencia. La calificación final obtenida fue de **5,18**.
- **Pruebas de Seguridad Informática:** Se planificó la realización de pruebas técnicas de seguridad, incluyendo: uso de Spiders, Robots y Crawlers; reconocimiento mediante motores de búsqueda; identificación de puntos de entrada; pruebas del receptor de escucha de la base de datos; búsqueda de archivos antiguos, copias de seguridad y sin referencia; identificación de interfaces de administración; pruebas de métodos HTTP y XST; pruebas de fuerza bruta; y pruebas de inyección SQL. **Estas pruebas no pudieron ser ejecutadas** debido a que el servicio de hosting del portal web expiró y no fue reactivado durante el periodo de la auditoría.

9. IDENTIFICACIÓN DE RIESGOS, AMENAZAS Y VULNERABILIDADES

Hallazgo	Proceso COBIT	Descripción Breve	Probabilidad de Ocurrencia	Impacto según Relevancia
HHDN_01	PO1	Inexistencia de un plan estratégico y de un grupo de evaluación para la red.	100% (Alto)	Alto (Catastrófico)
HHDN_02	PO3	Falta de políticas para el	71.43% (Alto)	Alto

Hallazgo	Proceso COBIT	Descripción Breve	Probabilidad de Ocurrencia	Impacto según Relevancia
		estudio de nuevas tecnologías y su documentación.		(Catastrófico)
HHDN_03	PO4	Inexistencia de manual de funciones, roles, responsabilidades y plan de contingencia para el personal de TI.	100% (Alto)	Alto (Catastrófico)
HHDN_04	PO5	Falta de un proceso de priorización de la inversión y de políticas de presupuesto para TI.	71.43% (Alto)	Alto (Catastrófico)
HHDN_05	PO9	Ausencia de políticas de análisis y gestión de riesgos, plan de contingencia y pólizas de seguro para la red.	100% (Alto)	Alto (Catastrófico)
HHDN_06	AI2	Inexistencia de software de monitoreo de la red y su respectivo mantenimiento.	100% (Alto)	Alto (Catastrófico)
HHDN_07	AI3	Deficiencias en adquisición, mantenimiento de infraestructura, cableado y documentación de equipos.	26.53% (Bajo)	Bajo (Leve)
HHDN_08	DS12	Inexistencia de políticas de seguridad física, control de acceso y protección ambiental para las	90.9% (Alto)	Alto (Catastrófico)

Hallazgo	Proceso COBIT	Descripción Breve	Probabilidad de Ocurrencia	Impacto según Relevancia
		instalaciones.		
HHDN_09	ME2	Ausencia total de políticas, procedimientos y responsables para el monitoreo de la red de datos.	100% (Alto)	Alto (Catastrófico)

Las principales amenazas y vulnerabilidades identificadas se derivan de la falta de controles formales. La información y los activos de red están expuestos a riesgos de hurto, sabotaje, daños por desastres ambientales (incendios, al no haber detectores de humo), interrupciones prolongadas del servicio por falta de planes de contingencia y monitoreo, y pérdida de integridad por la ausencia de procedimientos estandarizados de mantenimiento y documentación.

10. HALLAZGOS

A continuación se presenta un resumen de los nueve hallazgos documentados en el proceso de auditoría:

- **Hallazgo 1 (PO1):** No existe un grupo encargado de evaluar el desempeño de la red ni políticas para la conformación de su arquitectura física. Consecuencia: falta de claridad para la toma de decisiones y desaprovechamiento para ajustar los servicios de red a las necesidades de la entidad.
- **Hallazgo 2 (PO3):** No existen políticas para el estudio de nuevas tecnologías para la red ni se documentan dichos estudios. Consecuencia: se limita la optimización de los procesos de la red y se dificulta la implementación futura de mejoras.
- **Hallazgo 3 (PO4):** No existe un manual de funciones para el personal de administración de la red, ni definición de cargos, requisitos mínimos o plan de contingencia ante su ausencia. Consecuencia: se atenta contra el óptimo desempeño de las tareas y se interrumpen procesos ante la falta de personal clave.
- **Hallazgo 4 (PO5):** No se prioriza la inversión en elementos tecnológicos para la red ni existen políticas para la elaboración de un presupuesto de TI. Consecuencia: se limita el funcionamiento óptimo del sistema de red y la adquisición de herramientas necesarias.

- **Hallazgo 5 (PO9):** Inexistencia de políticas para la gestión de riesgos de la red, plan de contingencia y pólizas de seguro para sus elementos. Consecuencia: se carece de mecanismos para reaccionar ante eventos que afecten la conexión y se pierde la capacidad de restaurar y reconectar el sistema de forma ágil.
- **Hallazgo 6 (AI2):** No se cuenta con software para monitorear la conexión física de la red ni con su respectivo mantenimiento. Consecuencia: se pierde el control sobre la conexión global de la red, dificultando la identificación y solución de errores.
- **Hallazgo 7 (AI3):** No existen múltiples cotizaciones para la compra de hardware, ni documentación de políticas de mantenimiento de equipos, actas de recepción, manual de funciones para el personal de mantenimiento, planos del cableado estructurado, ni un seguimiento adecuado a los equipos de comunicación. Consecuencia: se pueden generar sobregastos, falta de control y retrasos en las actividades de mantenimiento y corrección de fallas.
- **Hallazgo 8 (DS12):** No existen políticas de seguridad para el acceso físico a las instalaciones, ni mecanismos de identificación, requisas, escolta de visitantes, protección contra eventos ambientales, pólizas de seguro, ni dispositivos de detección y prevención de incendios en el cuarto de servidores. Tampoco hay cámaras de monitoreo. Consecuencia: alto riesgo de hurto, sabotaje y pérdida de información y activos de la red ante desastres.
- **Hallazgo 9 (ME2):** Inexistencia de políticas, procedimientos, responsables y periodicidad definida para el monitoreo de la seguridad física de la red. No se realizan auditorías de ningún tipo a los componentes de la red. Consecuencia: se pierde la capacidad de seguimiento, prevención y corrección de eventos que afecten el funcionamiento de la red.

11. RESULTADOS OBTENIDOS Y ALCANCE DE LO AUDITADO

Como resultado de la aplicación de la auditoría, cuyo alcance cubrió la infraestructura física de la red de datos de la sede principal y la verificación del portal web institucional, se obtuvieron las siguientes conclusiones:

11.1. Sobre la Infraestructura Física de la Red de Datos

Los resultados de la auditoría, agrupados por dominio COBIT, evidencian un nivel de riesgo general alto debido a la falta de controles y procedimientos formales:

- **En Planificación y Organización:** Se encontró que la planeación es prácticamente inexistente; los problemas se resuelven de manera reactiva. Hace falta un manual de funciones para el área de sistemas y no existen políticas ni planes de contingencia para la red. A pesar de ello, el coordinador y el personal de sistemas investigan y proponen nuevas tecnologías a la gerencia por iniciativa propia.

- **En Adquisición e Implementación:** No se utiliza software de monitoreo de red, lo que genera pérdida de tiempo en la detección de fallas. Aunque no hay manuales formales, el personal de sistemas posee los conocimientos para dar soporte a la infraestructura de manera eficaz.
- **En Entrega y Soporte:** La administración de las instalaciones es deficiente. No hay políticas de seguridad para el acceso, y los equipos de comunicación se ubican en áreas no recomendables y sin protección contra incendios. Se destaca que los funcionarios han comenzado a solicitar a la gerencia los equipos necesarios para mitigar estos riesgos.
- **En Monitoreo y Evaluación:** No se realiza ningún tipo de monitoreo formal a la red de datos, ya que no existen procedimientos que lo exijan. No obstante, el equipo de sistemas conoce la red y puede dar respuesta a inconvenientes basándose en su experiencia.

11.2. Sobre el Portal Web y el Cumplimiento del Decreto 1151

- **Cumplimiento:** El portal web de la E.S.E. Centro Hospital Divino Niño **no cumple con los lineamientos establecidos en el Decreto 1151 de 2008**. De 49 criterios evaluados, solo se cumplen 11, lo que evidencia una falencia mayor que requiere corrección inmediata. Se destacan carencias como la falta de un comité de Gobierno en Línea, información institucional incompleta, ausencia de normatividad, presupuestos, planes, trámites, mecanismos de contratación, rendición de cuentas e interacción con el ciudadano.
- **Usabilidad:** La evaluación cuantitativa otorgó una nota de **5,18**, la cual se considera baja. Se identificaron errores como enlaces rotos o deshabilitados, contenido desorganizado, combinación de colores deficiente, errores de distribución de texto y de ortografía.
- **Pruebas Técnicas de Seguridad:** Las pruebas de seguridad informática planeadas no se ejecutaron debido a la caducidad del servicio de hosting durante el periodo de auditoría.